NON-FUNCTIONAL REQUIREMENTS (NFR)

Quality Attributes: Scalability & Security

Phân tích, xây dựng kịch bản đo lường và áp dụng các chiến thuật kiến trúc (Architectural Tactics) đảm bảo khả năng co giãn và an toàn hệ thống.

CHỦ ĐỀ
Thuộc tính Chất lượng Kiến trúc (Quality Attributes)

TRỌNG TÂM
Scalability & Security

Thuộc tính Chất lượng là gì?

Bản chất Thuộc tính Chất lượng

Nếu **Yêu cầu Chức năng (Functional Requirements)** xác định hệ thống *làm được những gì*, thì **Thuộc tính Chất lượng (Quality Attributes)** định lượng hệ thống *vận hành tốt đến mức nào* trong các điều kiện tải và mối đe dọa thực tế.

> **Kiến trúc phần mềm hình thành chủ yếu để thỏa mãn các thuộc tính chất lượng then chốt.**

Scalability (Khả năng mở rộng)

Khả năng đáp ứng tải trọng gia tăng (users, logs, concurrent jobs) mà vẫn duy trì hiệu năng chấp nhận được bằng cách bổ sung tài nguyên.

Security (Tính bảo mật)

Năng lực chống trả, phát hiện, khắc phục các hành vi truy cập trái phép và bảo vệ tính Toàn vẹn (Integrity), Bí mật (Confidentiality), Sẵn sàng (Availability).

Cấu Trúc Kịch Bản Đo Lường (QA Scenario)

Mọi thuộc tính chất lượng không thể nói chung chung (như "hệ thống phải mở rộng tốt"), mà phải được đặc tả qua 6 thành phần định lượng:

1. SOURCE

Nguồn kích thích

Người dùng đồng thời, hacker, hệ thống ngoại vi, tiến trình tự động.

2. STIMULUS

Tác nhân kích thích

Tải yêu cầu tăng vọt x10, upload log nặng 500MB, tấn công brute-force token.

3. ARTIFACT

Thành phần bị tác động

API Gateway, Python Mining Engine, Database MongoDB, GCS Storage.

4. ENVIRONMENT

Môi trường

Vận hành bình thường, chế độ quá tải cao điểm, hoặc khi hệ thống đang phục hồi.

5. RESPONSE

Phản ứng hệ thống

Tự động scale pod, chuyển tác vụ vào hàng đợi, từ chối request độc hại, ghi log.

6. MEASURE

Chỉ số đo lường

Throughput > 1000 req/s, Latency < 200ms, tỷ lệ phát hiện vi phạm 100%.

Kịch Bản Cụ Thể Cho Scalability

Kịch bản 1: Tải Log Sự Kiện Lớn (Data Scalability)

DATA LOAD

Source:	Nhóm phân tích nghiệp vụ upload đồng thời
Stimulus:	Tệp log XES/CSV dung lượng tăng từ 10MB lên 500MB+
Artifact:	Module Chuẩn hóa & Fast Miner (FastAPI Engine)
Environment:	Giờ cao điểm tải dữ liệu, hệ thống đang phục vụ dashboard
Response:	Chunk stream lên GCS, xử lý nền Celery không chặn Main API
Measure:	**Bộ nhớ RAM không vượt 80%, API Gateway phản hồi < 150ms**

Kịch bản 2: Đồng Thời Chạy What-If (Job Scalability)

COMPUTE LOAD

Source:	Nhiều người dùng kích hoạt kịch bản mô phỏng SimPy
Stimulus:	Số lượng phiên mô phỏng lặp lại tăng đột biến gấp 5 lần
Artifact:	Worker Pool Celery, Hàng đợi thông điệp Redis
Environment:	Các tài nguyên tính toán cục bộ đạt ngưỡng cảnh báo
Response:	HPA nhân bản thêm Worker node tự động, hàng đợi không drop job
Measure:	**100% tác vụ hoàn thành, thời gian chờ hàng đợi < 60s**

Các Chiến Thuật Cho Scalability (SEI Tactics)

Quản Lý Tài Nguyên

MANAGE RESOURCES

Increase Resources: Nâng cấp CPU/RAM máy chủ (Vertical Scaling) khi cần tức thời.

Maintain Replicas: Nhân bản các bản sao stateless worker qua Kubernetes / Docker Swarm (Horizontal).

Stateless Services: Đẩy toàn bộ session, file đệm ra Redis và Google Cloud Storage.

Điều Tiết Nhu Cầu

MANAGE DEMAND

Manage Event Arrival: Dùng Celery Task Queue làm đệm hấp thụ request tính toán đột ngột.

Rate Limiting: Giới hạn số lượng request API/phút đối với từng API token người dùng.

Sampling / Filtering: Bộ tiền xử lý chỉ chọn mẫu đại diện với các file log vượt quá 2 triệu dòng.

Giảm Thiểu Tải Trùng

CACHING & SHARING

Semantic QA Cache: Sử dụng bge-m3 + Chroma vector DB lưu các câu trả lời LLM tương tự.

Result Memoization: Lưu kết quả ma trận trực tiếp DFG, không tính toán lại nếu file hash không đổi.

Read/Write Separation: Tách biệt luồng query dashboard và luồng ghi event log vào Mongo.

Kịch Bản Cụ Thể Cho Security

Kịch bản 1: Truy Cập Trái Phép Dataset (Confidentiality)

UNAUTHORIZED ACCESS

Source:	Người dùng ngoài Workspace hoặc token bị lộ
Stimulus:	Cố tình gọi API lấy dữ liệu nhạy cảm của Workspace khác (IDOR)
Artifact:	Middleware Xác thực Node.js & Bảng phân quyền RBAC
Environment:	Môi trường công khai trên Internet
Response:	Từ chối mã lỗi 403 Forbidden, ghi vết Audit Log có IP & User ID
Measure:	**0% dữ liệu bị rò rỉ, cảnh báo tới quản trị viên trong < 5s**

Kịch bản 2: Thu Hồi Token Đăng Xuất (Integrity)

TOKEN REVOCATION

Source:	Kẻ tấn công đánh cắp token của phiên đã đăng xuất
Stimulus:	Tái sử dụng JWT token cũ để gửi request sửa/xóa dataset
Artifact:	Auth Layer và Blacklist Token trong Redis Cache
Environment:	Người dùng vừa thực hiện hành động Logout trên client
Response:	Kiểm tra danh sách blacklist Redis, huỷ phiên lập tức, trả về 401
Measure:	**Token vô hiệu hóa 100% ngay tại thời điểm đăng xuất thành công**

Các Chiến Thuật Cho Security (SEI Tactics)

Phát Hiện Tấn Công

DETECT ATTACKS

Detect Intrusion: Giám sát tần suất gọi API bất thường và request vượt payload chuẩn.

Verify Message Integrity: Kiểm tra SHA-256 checksum của file log khi tải lên GCS.

Audit Trails: Ghi log toàn bộ phiên thao tác dữ liệu (Ai - Khi nào - Làm gì) vào Audit Log độc lập.

Chống Đỡ Tấn Công

RESIST ATTACKS

Authenticate & Authorize: JWT kết hợp RBAC 3 vai trò (Admin, Editor, Viewer).

Encrypt Data: Sử dụng TLS 1.3 trong truyền dẫn và Bcrypt mã hóa mật khẩu người dùng.

Limit Exposure: Che giấu trực tiếp Python Core đằng sau Node Gateway; dùng GCS Signed URL có hạn.

Khắc Phục & Phục Hồi

REACT & RECOVER

Revoke Access: Thu hồi token trên Redis Blacklist ngay khi phát hiện xâm nhập.

Isolate Component: Tự động ngắt kết nối Worker bị lỗi khỏi cụm Celery để tránh lan tỏa.

State Restoration: Khôi phục dữ liệu từ các bản sao lưu tự động (Backup) trên MongoDB Cloud.

Hiện Thực Scalability & Security Theo Tầng

Tầng Kiến trúc (Tier)	Hiện thực Scalability (Khả năng mở rộng)	Hiện thực Security (Tính bảo mật)
API Gateway & Ingress	Load Balancing, non-blocking I/O, định tuyến cụm microservices, xử lý stream truyền tải dữ liệu.	Xác thực Token JWT Bearer, Rate Limiting chống DoS, giải mã TLS termination tập trung.
Application & Compute	Tách biệt CPU-bound và I/O-bound, co giãn tự động Stateless Pods qua Kubernetes HPA.	Phân quyền theo vai trò (RBAC), kiểm tra Input Validation, cô lập mạng Private Subnet.
Async Queue & Cache	Message Broker làm đệm giảm tải tức thời (Spike Buffering), In-memory caching kết quả tính toán.	Blacklist kiểm tra thu hồi token lập tức khi logout, mã hóa kênh truyền nội bộ bằng mTLS.
Database & Object Storage	Read/Write replica splitting, lưu trữ Object Storage phi trạng thái mở rộng không giới hạn dung lượng.	Mã hóa dữ liệu tĩnh (Encryption at Rest), cấp quyền truy xuất file qua Signed URLs có thời hạn.

Cân Bằng Đánh Đổi: Scalability vs Security

Mã hóa & Chi phí Tính toán

Xung đột: Tăng cường mã hóa toàn diện (Bcrypt vòng lặp cao, HTTPS, giải mã stream log) tiêu tốn đáng kể CPU, giảm khả năng mở rộng thông lượng của Node.js.

Giải pháp cân bằng: Sử dụng Hardware-accelerated TLS, điều chỉnh salt rounds Bcrypt hợp lý, chỉ mã hóa các trường thông tin nhạy cảm.

JWT Stateless vs Blacklist Bộ nhớ

Xung đột: JWT thuần túy là stateless (rất tốt cho Scalability), nhưng để thu hồi token khi đăng xuất (Security) buộc phải lưu trạng thái Blacklist.

Giải pháp cân bằng: Đặt hạn ngắn cho Access Token (15 phút) kết hợp Refresh Token; dùng Redis in-memory tra cứu O(1) với TTL tự hủy.

⚖ **Nguyên lý cốt lõi:** Không có thuộc tính chất lượng nào đứng độc lập. Kiến trúc sư phần mềm phải chủ động chọn điểm đánh đổi (Sweet Spot) dựa trên mục tiêu nghiệp vụ.

BALANCED DESIGN

Hệ Thống Mạnh Mẽ • Tin Cậy • Co Giãn

Việc đặc tả định lượng qua **QA Scenarios** và áp dụng đúng **Architectural Tactics** là chìa khóa giúp hệ thống Process Mining xử lý khối lượng dữ liệu khổng lồ an toàn tuyệt đối.

1. Đo lường định lượng

Xây dựng kịch bản với Response Measure cụ thể thay vì mô tả định tính.

2. Phân lập nhiệm vụ

Tách biệt I/O và CPU-bound kết hợp hàng đợi bất đồng bộ Celery + Redis.

3. Phòng thủ chiều sâu

Kiểm soát RBAC, bảo vệ token, audit log và triển khai SLM an toàn nội bộ.